

Vulnerability Disclosure Policy (VDP) Audit Report

Target: U.S. Department of Defense (DoD)

Consultant: Mohamad Ghaoui

Date: June 8, 2026

Course: IT-157 Phase 3

1. Executive Summary

This report audits the U.S. Department of Defense Vulnerability Disclosure Policy (VDP) hosted on HackerOne. The purpose of this analysis is to evaluate the legal protections, strict boundaries, and validation processes that the DoD enforces for independent security researchers.

2. Safe Harbor Analysis (The Commitment)

In penetration testing and bug bounty hunting, "Safe Harbor" is the legal protection provided to researchers who follow the rules. Because the federal Computer Fraud and Abuse Act (CFAA) treats unauthorized access as a crime, a VDP acts as the required "authorization."

According to the DoD policy's Legal section, if a researcher complies with the VDP terms, the DoD commits to the following Safe Harbor protections:

- The DoD will **not** initiate or recommend any law enforcement action or civil lawsuits against the researcher.
- If a third party or another law enforcement agency tries to prosecute the researcher, the DoD will formally inform them that the researcher's activities were authorized and conducted in compliance with DoD rules.

This means the researcher is protected from CFAA prosecution as long as they stay strictly within the defined scope.

3. The "Kill Switch" (Out of Scope Activities)

A "Kill Switch" in a VDP defines the absolute red lines. Crossing these lines immediately revokes the Safe Harbor protection, turning the researcher from an authorized professional into a criminal target. Based on the DoD Guidelines, the following three activities are strictly forbidden:

1. **Denial of Service (DoS):** Researchers are strictly forbidden from conducting DoS or DDoS testing that could degrade or crash military networks.
2. **Data Exfiltration & Privacy Violations:** Researchers may not exfiltrate (download/steal) any data under any circumstances. They also cannot intentionally compromise the privacy, safety, or intellectual property of DoD personnel.
3. **Physical Testing & Social Engineering:** The VDP only covers remote, technical testing. Physical breaches (tailgating into offices) and social engineering (spear-phishing employees) are completely out of scope.

4. Verification (Valid vs. Duplicate vs. Informational)

When a researcher submits a report, the DoD Cyber Crime Center (DC3) must investigate and verify it before the researcher receives credit. On the HackerOne platform, findings are classified as follows:

- **Valid:** The researcher provides a detailed summary, including a proof-of-concept and step-by-step instructions. The DoD security team successfully reproduces the exploit and confirms the vulnerability exists on an in-scope, publicly accessible DoD system.

- **Duplicate:** The vulnerability is real, but another researcher has already reported it to the DoD. Only the first person to report a valid vulnerability receives the credit/Safe Harbor acknowledgment.
- **Informational (or Ineligible):** The report highlights a theoretical issue, a scanner output with no real-world impact, or an issue categorized as a "Core Ineligible Finding" under the DoD scope exclusions. It does not pose a direct security threat to the network.